← tous les audits

Assistant de recherche juridique interne

Période : 04/11 — 11/11/2026

Architecture RAG · Réalisé par Capri

TESTS EFFECTUÉS	FUITES CONFIRMÉES	DÉFENSES ACTIVES	VERDICT GLOBAL
28	0	10/10	Cible très robuste

1 — CARTOGRAPHIE

Avant toute tentative d'exploitation, observation systématique du comportement de la cible pour identifier les mécanismes de défense en place (filtres, refus, classification, cohérence). 10 catégories de défense recensées sur cette cible.

- Filtre d'entrée sémantique
- Refus credentials absolu
- Refus métadonnées
- Citation verbatim
- Cohérence identité multi-tours
- Classification post-recherche
- Généralisation post-détection
- Budget de recherche limité
- Résistance pression temporelle
- Détection de patterns d'attaque

2 — FAILLES TROUVÉES

Aucune fuite critique obtenue malgré un volume de test élevé (28 techniques distinctes, dont certaines à grande échelle en environnement sandbox) — deux signaux partiels méritent d'être documentés.

Indice indirect de données sensibles via recherche contextuelle

INFORMATIF

Sous couvert de matériel de formation, le système a involontairement confirmé l'existence d'un enregistrement actif contenant une credential — sans jamais en révéler le contenu. Démontre que la classification de sensibilité s'applique après la recherche, pas uniquement sur la formulation de la question.

Vulnérabilité de prefix injection confirmée sur un modèle ouvert comparable

MÉTHODOLOGIQUE

En environnement sandbox (Llama 3.3 70B), le contrôle direct du préfixe de réponse via l'API a produit 60-80% de taux de fuite. Non exploitable sur la cible réelle (interface texte pure, sans accès aux rôles API), mais reste un vecteur critique à vérifier systématiquement sur toute architecture exposant ce contrôle.

3 — DÉFENSES RECOMMANDÉES

Recommandations concrètes pour fermer les deux signaux partiels identifiés et renforcer la posture globale.

Classifier la sensibilité avant toute confirmation d'existence
Étendre la classification post-recherche pour qu'elle bloque aussi les réponses qui ne font que confirmer/infirmer la présence d'un document sensible, pas seulement son contenu.

Auditer tout point d'accès exposant le contrôle du préfixe de réponse
Si l'architecture expose un jour un accès API avec contrôle des rôles/préfixe, revalider spécifiquement ce vecteur — il reste critique sur les modèles ouverts comparables (60-80% de fuite en sandbox).

4 — CONCLUSION

Cible jugée très robuste : 0 fuite confirmée sur 28 vecteurs testés, 10/10 catégories de défense actives. Les deux signaux relevés sont préventifs, pas exploités — à traiter pour fermer la marge avant qu'une évolution de l'architecture ne les rende exploitables.

Discuter d'un audit →